



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Iran-linked Handala group targets Cal Water, exposing potential pathways between IT and OT environments

Threat Actor Profile

Classification	TLP:CLEAR
Published	2026-06-16
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Actor Profile

TLP:CLEAR | Lost Boys Cyber | Iran-linked Handala group targets Cal Water, exposing potential pathways between IT and OT environments - Threat Actor Profile

Published: 2026-06-16 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

1. Executive Summary

Lost Boys Cyber assesses with moderate-to-high confidence that the Iran-linked Handala claim against California Water Service (Cal Water) is best treated as a confirmed data-exposure and credential-compromise event with unconfirmed operational-technology impact. Industrial Cyber, citing Dataminr analysis, reported that Handala published a 5 GB proof-of-concept data set allegedly containing customer billing information, personally identifiable information (PII), and administrative credentials tied to an RTKBase/NTRIP GPS correction network used across multiple Cal Water service districts. The source reporting states there is no public evidence that water production, treatment, distribution, SCADA, or chemical dosing systems were disrupted.

The operational significance is the pathway, not merely the breach claim. RTKBase is an operational-support technology used by field crews for precision GPS corrections when mapping and maintaining water infrastructure. If such a system is internet-exposed or weakly segmented from customer systems, it can become a credible initial-access or lateral-pivot point between operational-support infrastructure and enterprise billing environments. The reported pairing of RTKBase administrative access and customer billing data therefore indicates a practical IT/OT adjacency risk even without confirmed PLC or SCADA compromise.

Field	Assessment
Report ID	LBC-TAP-2026-011
Report Family	Threat Actor Profile
Primary Analytic Focus	Handala targeting of a U.S. water utility and the defensive implications of RTKBase/NTRIP exposure
Source Trigger	Industrial Cyber article published 2026-06-16, citing a Dataminr Cyber Intel Brief
Affected Organization	California Water Service (Cal Water), as reported by public sources
Claimed Actor	Handala / Handala Hack, an Iran-linked persona associated in reporting with Banished Kitten / Void Manticore / Storm-0842-aligned activity
Reported Exposure	Customer billing PII, RTKBase administrative credentials, NTRIP mountpoint source password, and IP-range enumeration across seven district deployments
Confirmed OT Impact	None publicly confirmed in the source reporting
Priority	High for water/wastewater utilities and any industrial operator using GNSS correction, NTRIP, remote field-support, or operational-support applications adjacent to customer or OT environments
Confidence	Moderate-to-high for data/credential exposure based on source detail; medium for the exact intrusion path; low for any claim of water-service disruption

Lost Boys Cyber recommends immediate credential rotation, exposure review, and network-path validation for RTKBase or similar GNSS/NTRIP deployments. Water-sector defenders should treat operational-support systems as sensitive conduits: they may not directly control treatment processes, but they can expose infrastructure maps, field-work context, credentials, and pivot opportunities that make later IT, OT, or influence operations more credible.

2. Intelligence Requirement

This report answers the following intelligence requirement:

Requirement	Answer
Primary question	What does the Handala claim against Cal Water reveal about water-sector exposure between IT, operational-support, and OT-adjacent environments?
Secondary question	What defensive controls and hunts should water and critical-infrastructure operators apply to RTKBase/NTRIP, billing, and remote operational-support systems?
Operational decision supported	Whether utilities should treat GNSS correction systems and similar operational-support applications as low-risk field tools or as high-value conduits requiring segmentation, monitoring, and credential governance
Time horizon	Immediate triage for exposed RTKBase/NTRIP services and billing access logs; 30–90 day segmentation and monitoring uplift for operational-support networks

Analytic assumptions used in this report:

- Public reporting is sufficient to support defensive action, but not sufficient to assert complete intrusion scope.
- The leaked proof-of-concept data reportedly contains credentials and PII; this report deliberately avoids reproducing any sensitive credential, IP-range, or customer-data values.
- Handala’s service-disruption claims remain unproven in the cited source; defenders should not dismiss the incident, but should separate confirmed exposure from actor propaganda.
- RTKBase/NTRIP systems are treated here as operational-support infrastructure. They may sit outside classic control layers while still supporting field operations and asset-maintenance workflows.
- Detection content below is provided as starting logic and must be tuned to local SIEM, EDR, historian, firewall, billing, NTRIP, and web-server telemetry.

3.1 Source summary

The primary source is Industrial Cyber’s 16 June 2026 report, “Iran-linked Handala group targets Cal Water, exposing potential pathways between IT and OT environments.” The article cites Dataminr analysis of Handala’s public breach claim and describes a proof-of-concept data dump that allegedly included Cal Water customer billing data, PII, RTKBase administrative credentials, an NTRIP mountpoint source password, and IP-range information for seven district deployments.

Source element	Relevance	Lost Boys Cyber evaluation
Industrial Cyber article	Primary narrative source for the incident and defensive implications	Credible industrial-security trade reporting; article is source-rich but still depends heavily on Dataminr’s analysis of actor-published material
Dataminr Cyber Intel Brief, as quoted by Industrial Cyber and indexed by search results	Core technical assessment: billing PII, RTKBase/NTRIP access, credentials, seven district mountpoints, and probable pivot pathway	High value for triage; direct source access was restricted during this review, so this report cites Dataminr through accessible public reporting
CISA Iran state-sponsored cyber threat advisory index	Corroborates broader U.S. concern around Iranian-affiliated cyber activity against critical infrastructure, including OT devices	Strong context source; does not independently confirm this specific Cal Water intrusion
SecurityWeek / Security Boulevard /	Corroborate public reporting around	Useful corroboration; secondary sources

Security Affairs search-result summaries	RTKBase, 5 GB data leak, credentials, and unconfirmed operational impact	should not be treated as forensic proof
RTKBase / NTRIP technical context	Explains why a GNSS correction service can matter in a utility environment	Requires local validation: actual exposure, segmentation, and logging vary by deployment

3.2 Confidence assessment

Judgment	Confidence	Rationale
Handala publicly claimed responsibility for a Cal Water compromise	High	Multiple public sources report the claim and cite the same actor narrative
Actor-published material included customer billing PII and RTKBase/NTRIP credentials	Moderate-to-high	Industrial Cyber cites Dataminr analysis with concrete data categories; this review did not access the leaked data and does not reproduce sensitive values
RTKBase was a probable initial-access vector or lateral pivot into billing systems	Medium	Dataminr reportedly assessed this pathway; billing and RTKBase are distinct systems, and public reporting does not prove the full intrusion chain
Water treatment, distribution, chemical dosing, or SCADA operations were disrupted	Low	Industrial Cyber explicitly reports no evidence of operational disruption or confirmed SCADA impact
Handala has capability and intent to escalate from data exposure to destructive or psychological operations	Moderate	Public reporting links Handala to destructive tooling and influence-oriented operations; incident-specific destructive action is not confirmed
Similar exposure patterns are relevant to other water/wastewater utilities	High	RTKBase/NTRIP, remote field tools, billing portals, and weak segmentation are common operational-support risk patterns

3.3 Intelligence gaps

- Cal Water’s official forensic scope, root cause, and containment actions were not available in the provided source.
- The exact authentication mechanism, internet exposure state, and segmentation path for the RTKBase deployment require direct environment validation.
- The number of affected customer records across all districts has not been independently verified in public reporting.
- No public packet captures, host telemetry, confirmed malware samples, or validated actor infrastructure were available for this report.
- Actor-attribution labels around Handala vary across vendors and public reporting; this report uses “Iran-linked Handala” while preserving uncertainty around command-and-control relationships.

4. Key Findings

ID	Finding	Defensive implication	Priority
KF-01	The reported compromise joins two risk domains: operational-support GPS correction infrastructure and customer billing data.	Treat RTKBase/NTRIP and similar field-support systems as sensitive conduits, not isolated utility tools.	High

KF-02	Public reporting identifies exposed or compromised credentials, including RTKBase administrative access and an NTRIP mountpoint source password.	Rotate all related credentials, hunt for reuse, and inspect service accounts that bridge billing, field, GIS, and OT-support networks.	Critical
KF-03	No public evidence confirms disruption to SCADA, treatment, or distribution systems.	Communicate risk accurately: data and credential compromise are credible; service-disruption claims remain unproven.	High
KF-04	Handala's claim has psychological and geopolitical utility even if operational impact is limited.	Expect follow-on propaganda, extortion, spear-phishing, and possible copycat scanning for exposed water-sector systems.	High
KF-05	RTKBase/NTRIP deployments may expose infrastructure mapping, district mountpoints, field-crew workflows, and network paths.	Include GNSS correction systems in asset inventories, external attack-surface management, and OT-adjacent segmentation reviews.	High
KF-06	Billing PII exposure creates downstream social-engineering risk for customers and utility personnel.	Prepare customer-notification, fraud-awareness, and targeted-phishing monitoring playbooks.	Medium-High
KF-07	The incident aligns with broader CISA warnings around Iranian-affiliated activity against U.S. critical infrastructure and OT devices.	Prioritize water-sector hardening where internet-facing OT or operational-support devices remain exposed.	High

5. Threat Context

Handala is a public-facing, Iran-linked cyber persona that blends hack-and-leak activity, psychological operations, and claims of disruptive capability. Public reporting maps Handala-related activity to several overlapping vendor labels, including Banished Kitten, Void Manticore, Storm-0842, Dune, Homeland Justice, and Red Sandstorm. The exact organizational relationship behind these labels is contested in open sources, but the defensive relevance is consistent: the persona is used to pressure U.S. and Israeli-aligned targets, amplify geopolitical messaging, and publish victim data for influence effect.

In the Cal Water reporting, the actor's value proposition was not stealth. The value was visibility: a claimed breach of a life-sustaining critical-infrastructure operator, screenshots or data meant to prove access, and messaging designed to suggest water-service disruption. That pattern should be read as a hybrid cyber and influence operation. Even limited billing-system access can be used to create public concern when paired with operational-support screenshots, district names, or infrastructure references.

Threat dimension	Relevance to this incident	Defensive interpretation
Geopolitical signaling	The actor framed the claim around U.S.-Iran tensions and "life-sustaining" infrastructure	Expect exaggeration, but do not dismiss the underlying exposure
Data theft and doxxing	Published material reportedly included customer billing PII and account records	Validate breach-notification requirements and downstream phishing risk

Credential compromise	RTKBase administrative and NTRIP source credentials were reportedly published in plaintext	Treat all exposed, reused, and adjacent secrets as compromised
Operational-support access	RTKBase supports field crews receiving centimeter-accurate GPS corrections	Include field-support applications in IT/OT risk reviews
Lateral movement potential	Dataminr reportedly assessed RTKBase as a probable initial access or pivot point	Validate segmentation between field-support, billing, GIS, enterprise, and OT environments
Destructive risk	Public reporting notes Handala-linked wiper capability including win.handala, Handala Wiper, and Hamsa Wiper	Hunt for destructive-preparation behaviors even if no wiper is confirmed in this case
Psychological impact	Claims of water disruption can erode public trust even without treatment-process compromise	Coordinate technical, legal, communications, and executive response early

The RTKBase/NTRIP component matters because many industrial organizations classify field-support systems as convenience infrastructure rather than as crown-jewel-adjacent services. GNSS correction networks can reveal service territories, field maintenance patterns, asset mapping activity, district mountpoints, and internal addressing. If these systems authenticate weakly, run on low-overhead devices, expose web administration, or share credentials with other operational systems, they become useful attacker footholds.

MITRE ATT&CK mapping

Tactic	Technique	Relevance to Cal Water / Handala scenario
Initial Access	External Remote Services (T1133)	Internet-exposed RTKBase, VPN, remote admin, or support portals may provide the first foothold if credentials or weak controls are present.
Initial Access	Valid Accounts (T1078)	Published administrative and NTRIP source credentials create immediate valid-account risk, including reuse against adjacent systems.
Discovery	Network Service Discovery (T1046)	Actor-published enumeration of NTRIP infrastructure suggests interest in mapping services, hosts, mountpoints, and exposed ports.
Discovery	Account Discovery (T1087)	Billing, RTKBase, and field-support systems may reveal users, service accounts, and district-specific roles.
Collection	Data from Information Repositories (T1213)	Customer billing databases and operational-support repositories can provide PII, account history, and infrastructure context.
Collection	Data from Local System / Network Shared Drive (T1005 / T1039)	Field-support hosts may store credentials, config files, logs, mountpoint settings, and GIS-related artifacts.
Credential Access	Unsecured Credentials (T1552)	Plaintext service passwords or configuration files are a key concern for

		RTKBase/NTRIP and small field-support deployments.
Lateral Movement	Remote Services (T1021)	Compromised credentials may enable movement from field-support or enterprise systems into billing, GIS, jump hosts, or OT-support networks.
Exfiltration	Exfiltration Over Web Service (T1567)	A 5 GB proof-of-concept dump implies staged or bulk data movement to actor-controlled or public-hosted infrastructure.
Impact	Data Destruction (T1485) / Disk Wipe (T1561)	Handala-linked reporting references wiper tooling; no wiper was confirmed in this incident, but destructive preparation should be hunted.
ICS Impact	Loss of View / Manipulation of View	If operational-support or mapping data is manipulated, field crews and operators may lose confidence in asset-location or maintenance context even without PLC compromise.

5.1 Indicators, Observables, and Source Limitations

No malware sample, verified attacker-owned IP address, payload hash, phishing domain, or public command-and-control endpoint was available in the open reporting reviewed for this assessment. Treat the following as defensive observables and scoping pivots rather than confirmed compromise IOCs.

Indicator / Observable	Type	Defensive Use	Confidence
Handala / Handala Hack	Actor persona / claimed intrusion brand	Correlate public leak claims, extortion posts, and Iran-linked psychological-operation narratives against utility-sector monitoring.	Medium
California Water Service / Cal Water	Victim organization	Scope customer-notification, brand-abuse, credential-reuse, and third-party exposure monitoring.	High
RTKBase	Operational-support application	Inventory NTRIP/GNSS correction hosts, verify internet exposure, and review administrative authentication paths.	Medium-High
NTRIP correction service	Operational-support protocol/service	Hunt for unusual access, credential reuse, and unexpected communications between field-support systems and billing or identity infrastructure.	Medium-High
Published billing data / PII claim	Data-exposure indicator	Drive breach-response, customer-fraud monitoring, dark-web review, and targeted-	Medium-High

		phishing detection.	
Administrative credentials allegedly tied to RTKBase/NTRIP	Credential-exposure indicator	Force rotation, review authentication logs, and check for reuse across GIS, billing, VPN, and OT-support systems.	Medium
No confirmed OT disruption	Source limitation	Avoid overstating SCADA, treatment, distribution, or chemical-dosing compromise without telemetry.	High

6. Detection and Hunting

Detection should focus on four questions: was RTKBase/NTRIP exposed, were credentials abused, was billing data exported, and is there any sign of destructive staging or movement toward OT-support systems. The logic below is intentionally defensive and does not include leaked credentials, victim IP ranges, or customer data.

6.1 Detection coverage plan

Coverage area	Telemetry source	High-value signals	Why it matters
RTKBase / NTRIP exposure	External attack-surface scans, firewall logs, web-server logs, reverse proxy, asset inventory	HTTP port 10000 exposure, NTRIP caster endpoints, admin UI access, new external clients, unusual user agents	Reported access centered on RTKBase/NTRIP infrastructure.
Credential abuse	IAM, VPN, PAM, Linux auth logs, application audit logs	Successful login from new source, failed bursts, reused admin credentials, service-account interactive logins	Published credentials must be assumed compromised.
Billing data access	Billing application logs, database audit, API gateway, DLP, EDR	Bulk account export, broad customer lookups, abnormal SQL/API volume, off-hours admin access	The reported dump included customer billing data and PII.
Segmentation violations	Firewall, NAC, OT sensor, router flow logs	RTKBase host reaching billing, GIS, OT jump hosts, historians, or domain controllers	Distinct systems should not have broad lateral paths.
Destructive staging	EDR, Sysmon, Windows event logs, backup logs	vssadmin, wbadmin, bcdedit, disk utilities, suspicious service stop, MBR/volume access	Handala-linked reporting references wiper capability.
Follow-on phishing	Email security, web proxy, helpdesk, identity logs	Cal Water-themed lures, customer-account pretexts, suspicious password resets	PII exposure enables targeted social engineering.

6.2 Sigma: exposed or abused RTKBase administration path

```

title: RTKBase or NTRIP Administration Access From Untrusted Network
id: 8bba2d50-7e50-4a37-9f14-lbc-handala-rtkbase-001
status: experimental
description: Detects web access to RTKBase/NTRIP administrative paths or port 10000 from external or untrusted sources. Tune path and host filters to local RTKBase deployments.
author: Lost Boys Cyber
date: 2026-06-16
references:

```

```
- https://industrialcyber.co/utilities-energy-power-water-waste/iran-linked-handala-group-targets-cal-water-exposing-potential-pathways-between-it-and-ot-environments/
logsource:
  category: webserver
detection:
  selection_port:
    cs-uri-port|contains:
      - '10000'
      - ':10000'
  selection_path:
    cs-uri-stem|contains:
      - 'rtkbase'
      - 'ntrip'
      - 'admin'
      - 'caster'
      - 'mountpoint'
  filter_internal:
    c-ip|cidr:
      - '10.0.0.0/8'
      - '172.16.0.0/12'
      - '192.168.0.0/16'
  condition: (selection_port or selection_path) and not filter_internal
fields:
  - date
  - time
  - c-ip
  - cs-host
  - cs-uri-stem
  - cs-uri-query
  - cs-user-agent
  - sc-status
falsepositives:
  - Approved external maintenance window through a controlled bastion or VPN
  - Security scanning from authorized external exposure management tools
level: high
```

6.3 KQL: RTKBase or NTRIP host reaching billing or identity infrastructure

```
let lookback = 14d;
let RTKHostHints = dynamic(["rtk", "rtkbase", "ntrip", "gnss", "cors", "gps-correction", "mountpoint"]);
let SensitiveDestHints = dynamic(["billing", "customer", "cis", "crm", "gis", "domain", "dc", "jump", "historian", "scada"]);
DeviceNetworkEvents
| where Timestamp > ago(lookback)
| where DeviceName has_any (RTKHostHints) or InitiatingProcessCommandLine has_any (RTKHostHints)
| extend DestinationLabel = strcat(RemoteUrl, " ", RemoteIP, " ", RemotePort)
| where DestinationLabel has_any (SensitiveDestHints) or RemotePort in (1433, 1521, 3306, 5432, 389, 636, 445, 3389, 5985, 5986, 502, 44818, 20000)
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Connections=count(), Destinations=make_set(DestinationLabel, 20), Processes=make_set(InitiatingProcessFileName, 20) by DeviceName, InitiatingProcessAccountName
| order by LastSeen desc
```

Purpose: surface suspicious lateral connectivity from RTKBase/NTRIP or GNSS correction systems into billing, identity, GIS, jump-host, historian, or OT-adjacent infrastructure.

6.4 KQL: billing-system bulk customer-data access

```
// Adapt table and field names to the local billing application, database audit, API gateway, or DLP logs.
let lookback = 14d;
BillingAudit_CL
| where TimeGenerated > ago(lookback)
| summarize
  AccountLookups=countif(Operation_s in~ ("read", "lookup", "query", "export")),
  UniqueCustomers=dcount(CustomerId_s),
```

```

ExportEvents=countif(Operation_s has_any ("export", "download", "dump", "bulk")),
SourceHosts=make_set(SourceHost_s, 20),
SourceIPs=make_set(SourceIP_s, 20),
SampleOperations=make_set(Operation_s, 10)
by bin(TimeGenerated, 1h), User_s, Application_s
| where UniqueCustomers > 500 or ExportEvents > 0 or AccountLookups > 5000
| project TimeGenerated, User_s, Application_s, AccountLookups, UniqueCustomers, ExportEvents,
SourceHosts, SourceIPs, SampleOperations
| order by TimeGenerated desc

```

Purpose: identify the sort of broad customer-record access or export activity consistent with a proof-of-concept billing-data dump.

6.5 KQL: published or reused operational-support credentials

```

let lookback = 30d;
let OperationalSupportAccounts = dynamic(["rtk", "rtkbase", "ntrip", "gnss", "fieldgps", "caster",
"survey", "gis-service"]);
SigninLogs
| where TimeGenerated > ago(lookback)
| where UserPrincipalName has_any (OperationalSupportAccounts) or AppDisplayName has_any
(OperationalSupportAccounts)
| summarize
    Attempts=count(),
    Failures=countif(ResultType != 0),
    Successes=countif(ResultType == 0),
    SourceIPs=make_set(IPAddress, 30),
    Apps=make_set(AppDisplayName, 20),
    Locations=make_set(Location, 20)
by bin(TimeGenerated, 1d), UserPrincipalName
| where Failures > 5 or Successes > 0 and array_length(SourceIPs) > 2
| order by TimeGenerated desc

```

Purpose: hunt for credential stuffing, password reuse, or unexpected successful use of accounts related to RTKBase/NTRIP, GIS, survey, and field-support services.

6.6 Splunk: destructive staging on utility support hosts

```

index=edr OR index=sysmon OR index=windows
(host=*billing* OR host=*rtk* OR host=*ntrip* OR host=*gis* OR host=*field* OR host=*jump*)
(process_name IN
("vssadmin.exe", "wbadmin.exe", "bcdedit.exe", "wevtutil.exe", "diskpart.exe", "wmic.exe", "powershell.exe", "
cmd.exe") OR command_line="*delete shadows*" OR command_line="*resize shadowstorage*" OR
command_line="*recoveryenabled no*" OR command_line="*bootstatuspolicy ignoreallfailures*" OR
command_line="*clear-log*" OR command_line="*format*" OR command_line="*\\.\PhysicalDrive*")
| stats count min(_time) as first_seen max(_time) as last_seen values(process_name) as processes
values(command_line) as commands values(parent_process_name) as parents by host user
| where count > 1 OR match(mvjoin(commands, " "), "delete shadows|recoveryenabled no|PhysicalDrive|
clear-log")
| convert ctime(first_seen) ctime(last_seen)
| sort - last_seen

```

Purpose: provide early warning for wiper-like or recovery-inhibition behavior on systems adjacent to the reported exposure, while recognizing that no destructive malware has been publicly confirmed in this case.

6.7 Threat-hunting hypotheses

Hypothesis	Hunt action	Expected benign explanation	Escalation condition
A public-facing RTKBase service was accessed by unauthorized infrastructure.	Review web, firewall, and proxy logs for port 10000, RTKBase admin paths, and NTRIP caster paths from non-approved IPs.	Approved vendor maintenance or exposure scanner.	Successful authentication, config download, credential view, or repeated access from anonymized hosting/VPN nodes.
RTKBase or field-support credentials were reused against	Search IAM/application logs for operational-support account	Legacy shared account used by	New geography, new source ASN, interactive use by service

billing, GIS, VPN, or identity systems.	names and failed/successful login attempts outside normal source networks.	field crews.	account, or access to customer data.
Billing data was bulk exported prior to publication.	Identify high-volume account lookups, database exports, file downloads, and unusually broad API queries around the suspected compromise window.	Scheduled reporting or regulatory export.	Export lacks change ticket, occurs off-hours, or originates from RTK/GIS/field-support hosts.
Operational-support hosts have unintended network reachability into IT or OT support systems.	Compare firewall/NAC flows from RTKBase/NTRIP/GIS hosts to billing, domain controllers, jump hosts, historians, and industrial protocols.	Documented management path through a bastion.	Direct east-west reachability, SMB/RDP/WinRM, database ports, or industrial protocol access outside approved conduits.
Handala or copycat actors are staging follow-on psychological or destructive activity.	Monitor actor-themed mentions, customer-targeted phishing, destructive command patterns, and backup-tampering events.	Media-driven noise or unrelated phishing.	Correlation with exposed customer data, utility-specific lures, or host telemetry showing recovery inhibition.

7. Recommendations

Priority	Recommendation	Owner	Target state
1	Rotate all RTKBase, NTRIP mountpoint, GIS, billing, VPN, and adjacent service-account credentials that may have been exposed or reused.	IAM / OT Security / Application Owners	No exposed secret remains valid; service accounts are unique, least-privileged, and monitored.
2	Remove internet exposure for RTKBase/NTRIP administrative interfaces; require VPN, bastion, or ZTNA access with MFA and source restrictions.	Network / OT Infrastructure	Administrative access is never directly reachable from the public internet.
3	Validate segmentation between RTKBase/NTRIP, GIS, billing, identity, remote-access, historian, and OT-support networks.	Network Architecture / OT Security	Field-support systems can reach only documented services through explicit conduits.
4	Review billing-system access for the suspected compromise window, including account lookups, bulk exports, API use, and database administrative actions.	Application Security / Data Owners	Confirmed scope of customer data exposure and preserved evidence for legal and notification decisions.
5	Add RTKBase/NTRIP/GNSS correction systems to asset inventory, vulnerability management, EASM, and	Asset Management / OT Operations	Operational-support tools are governed with the same discipline as other utility-

	backup/restore plans.		critical systems.
6	Preserve and review logs from RTKBase hosts, reverse proxies, firewalls, billing applications, VPN, identity providers, and EDR.	IR / SOC	Investigation has enough evidence to test credential abuse, lateral movement, and exfiltration hypotheses.
7	Prepare customer and employee anti-phishing messaging without overstating unconfirmed water-service impact.	Legal / Communications / Security Awareness	Stakeholders understand PII risk and social-engineering exposure while technical claims remain accurate.
8	Hunt for destructive staging and recovery-inhibition behavior on billing, GIS, jump, and operational-support hosts.	SOC / DFIR	Wiper preparation is detectable before impact, even though no wiper is confirmed in this incident.
9	Notify and coordinate with CISA, WaterISAC, law enforcement, and regulators as required by incident scope.	Executive / Legal / IR Lead	External coordination supports sector awareness and compliance obligations.
10	Run a tabletop exercise for “data breach plus claimed OT disruption” scenarios.	Executive / OT Operations / Communications	Incident response can separate technical truth, public claims, safety operations, and customer communications under pressure.

Near-term hardening checklist:

- Inventory every RTKBase, NTRIP caster, GNSS correction, GIS, survey, and field-support service.
- Confirm whether any administrative interface listens on public IP space or broad enterprise network ranges.
- Disable default, shared, or plaintext credentials; rotate secrets and move them into managed vaulting where possible.
- Require MFA or workload identity controls for administrative and remote access paths.
- Restrict source IPs and require bastion access for maintenance.
- Disable direct connectivity from field-support systems to billing or OT-support systems unless a documented business process requires it.
- Enable application, web, and host logging sufficient to answer who authenticated, what changed, and what data was exported.
- Add field-support hosts to EDR or equivalent host telemetry where technically feasible.
- Review backup, restore, and golden-image coverage for operational-support systems.
- Pre-stage communications that distinguish “customer data exposure,” “operational-support compromise,” and “water-service disruption.”

8. References

- [1] Industrial Cyber, “Iran-linked Handala group targets Cal Water, exposing potential pathways between IT and OT environments,” 2026-06-16. <https://industrialcyber.co/utilities-energy-power-water-waste/iran-linked-handala-group-targets-cal-water-exposing-potential-pathways-between-it-and-ot-environments/>
- [2] Dataminr, “Cyber Intel Brief: Handala Claims Breach of California Water Service,” referenced by Industrial Cyber and public search-result summaries, June 2026. <https://www.dataminr.com/resources/intel-brief/cyber-intel-brief-handala-claims-breach-of-california-water-service/>

- [3] CISA, “Iran State-Sponsored Cyber Threat: Advisories,” including 2026 warnings on Iranian-affiliated exploitation of internet-connected OT devices across U.S. critical infrastructure. <https://www.cisa.gov/topics/cyber-threats-and-advisories/nation-state-cyber-actors/iran/publications>
- [4] SecurityWeek, “Iranian Cyber Group Handala Claims Cal Water Hack,” June 2026. <https://www.securityweek.com/iranian-cyber-group-handala-claims-cal-water-hack/>
- [5] Security Boulevard, “Iranian Cyber Group Handala Claims Cal Water Hack,” June 2026. <https://securityboulevard.com/2026/06/iranian-cyber-group-handala-claims-cal-water-hack/>
- [6] Security Affairs, “Iran-Linked Handala Breached a California Water Utility. It Could Have Done Worse, and It Knows That,” June 2026. <https://securityaffairs.com/193565/uncategorized/iran-linked-handala-breached-a-california-water-utility-it-could-have-done-worse-and-it-knows-that.html>
- [7] RTKBase project documentation and NTRIP operational context, used for defensive interpretation of GNSS correction and caster exposure. <https://github.com/Stefal/rtkbase>